Introduction to Vulnerability Management - Course Challenge Report Template

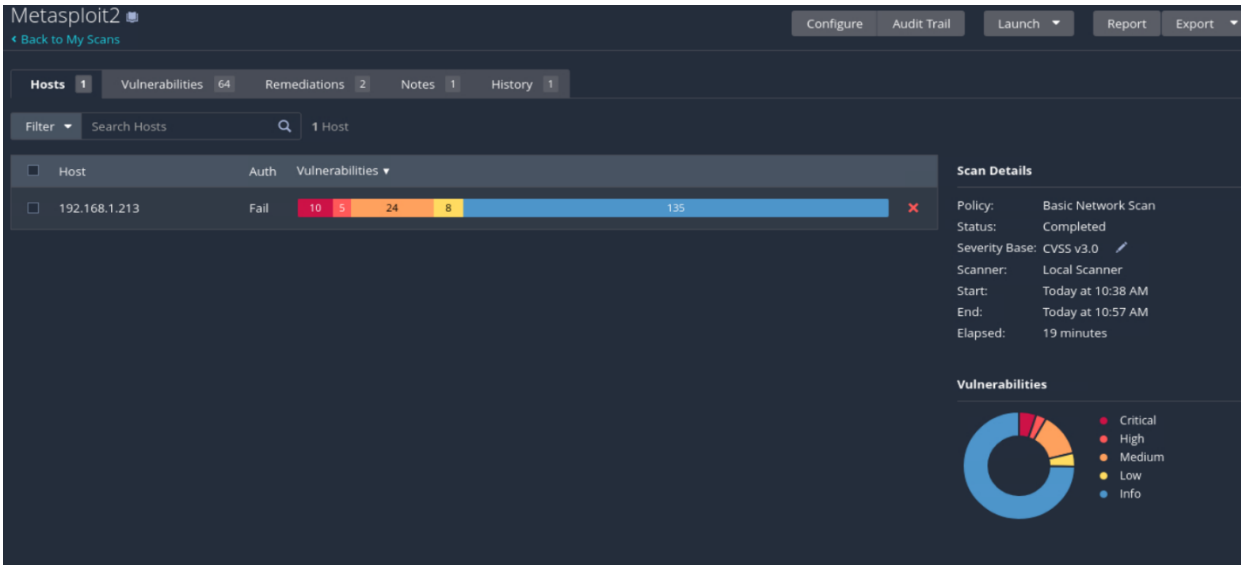
Name of Individual Conducting Scanning:	John
Nessus Scanner IP (IP of Kali VM):	172.21.200.97
Target Host IP (METASPLOIT2)	192.168.1.213
Date & Time Scan Started:	29/9/26 at 10:40 am EET
Date & Time Scan Finished:	29/9/26 at 11:00 am EET
Scan Details	Policy Basic Network Scan Severity Base: CVSS v3.0
Security Issues Identified:	64 vulnerabilities found

Instructions

1. Please refer to the Course Challenge Brief for instructions on what you are being asked to do.
2. Answer all questions mentioned below.

Overview

A vulnerability assessment was performed on September 29, 2026 using Nessus scanner on the 'Metasploitable 2' system with the IP address 192.168.1.213. The goal was to find vulnerabilities and check the system's overall security status. After a basic network scan, it found 64 vulnerabilities of varying severity levels. Based on the results the system's security level is assessed as critical , high , medium, low and info.

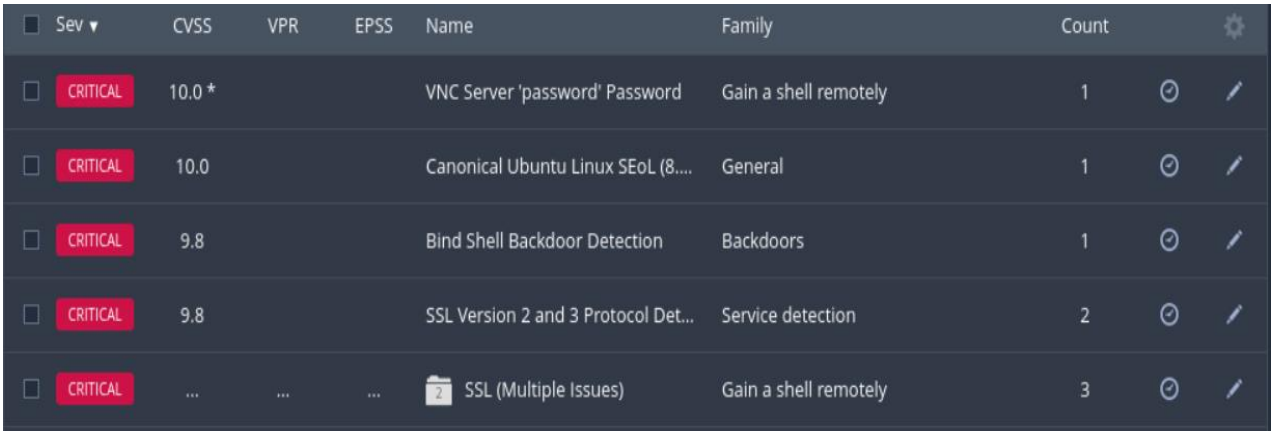


The result of the scan is as follows:

- 10 (5.49%) Critical Severity vulnerabilities were found
- 5 (2.75%) High Severity vulnerabilities were found
- 24 (13.19%) Medium Severity vulnerabilities were found
- 8 (4.40%) Low Severity vulnerabilities were found
- 135 (74.18%) Info findings about the system

The number 8.24% of Critical and High Severity vulnerabilities of the total findings indicates a significant level of vulnerability. Plus, the presence of Medium and Low Severity vulnerabilities further contributes to the system's overall vulnerability. So base on the scan results this system is vulnerable.

Top 5 Most Serious Security Issues (In priority order - most important first):



Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8....	General	1
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1
CRITICAL	9.8			SSL Version 2 and 3 Protocol Det...	Service detection	2
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3

The 5 most critical security issues are as shown below:

1. Canonical Ubuntu Linux End of Life (SEoL 8.04.x): The target host runs Ubuntu Linux 8.04.x (Hardy Heron), an operating system version that reached End of Life (EOL) in 2013. Canonical no longer provides security patches, software updates, or bug fixes for this release.

Risk/Impact: System-wide compromise. Unpatched local privilege escalation exploits, remote execution vulnerabilities, and outdated software libraries allow attackers to take full administrative control of the host.

2. Bind Shell Backdoor Detection: A command shell is listening on a network port without requiring any authentication. Anyone connecting to this port via standard network utilities (such as netcat or telnet) is immediately granted a command-line interface.

Risk/Impact: Remote Code Execution (RCE) with root privileges. Attackers can execute system commands, extract data, or use the host to pivot deeper into the internal network.

3. VNC Server Weak / Default Password: The Virtual Network Computing (VNC) service allows remote graphical desktop access and is secured with a weak, easily guessable, or default password.

Risk/Impact: Unauthorized external users can connect via a standard vncviewer client and interact with the host's desktop environment directly, bypassing normal system access controls.

4. Apache Tomcat Multiple Issues (SEoL & Default Manager Credentials): The installed Apache Tomcat application server exhibits multiple overlapping critical flaws: an unsupported End-of-Life server version (Tomcat 5.5.x), active default administrative accounts (tomcat:tomcat), and susceptibility to request injection vulnerabilities (Ghostcat / CVE-2020-1938).

Risk/Impact: Attackers can log into the Tomcat Manager web application, upload a malicious .war payload to obtain remote shell access, or read arbitrary application source files and sensitive database credentials.

5. SSL Version 2 and 3 Protocol Detection: The host accepts encrypted connections using obsolete SSL 2.0 and SSL 3.0 protocols. These legacy protocols contain structural cryptographic flaws, including weak Cipher Block Chaining (CBC) padding schemes and insecure session renegotiation.

Risk/Impact: Susceptible to Man-in-the-Middle (MitM) traffic interception, protocol downgrade attacks and plaintext decryption of secure session tokens or credentials.

Top 5 - Remediations (In priority order - most important first):

1. Canonical Ubuntu Linux End of Life (SEoL 8.04.x): Backup all critical database and web application files. Migrate the host to an actively supported Long-Term Support (LTS) operating system release (such as Ubuntu 22.04 LTS or 24.04 LTS).
2. Bind Shell Backdoor Detection: Terminate the rogue shell process, identify and remove the startup script or service triggering the shell and implement strict host-based firewall rules (ufw or iptables) to block unauthorized inbound connections on high-numbered ports.
3. VNC Server Weak / Default Password: Change the VNC password immediately using the vncpasswd utility to a complex password (at least 16 characters long). Reconfigure VNC to listen only on 127.0.0.1 (localhost) and enforce access through encrypted SSH tunnels or a private Virtual Network.
4. Apache Tomcat Multiple Issues (SEoL & Default Manager Credentials): Upgrade Apache Tomcat to a stable, supported release. Restrict or remove access to the administrative. Remove default roles and accounts.
5. SSL Version 2 and 3 Protocol Detection: Disable SSL v2 and SSL v3 globally across web server and service configurations. Restrict secure channels to accept only TLS 1.2 and TLS 1.3 protocols.